

GRC AI Agent

Software Design Document

04-25-2026

Team AI Agent

Alp Berrak and Carter Jules

Executive Summary

The Automated GRC AI Agent streamlines risk assessments and identifies applicable data-privacy regulations for organizations in the business and finance sector. The agent is implemented as an n8n workflow triggered from Slack. The workflow collects structured inputs (location, sector, states, user volume, and self-evaluation of system subsections) and executes three AI Agent nodes and uses Retrieval-Augmented Generation to pull supplemental information for the AI Agents to use from a GitHub. The supplemental information includes data privacy regulations and NIST recommendations formatted as JSONs for easy parsing and appending. The result is a concise, readable report returned to users via Slack DMs that reduces hallucination risk by constraining agents to the supplemental information provided by vector store tools.

Current limitations include scope restricted to the business/finance sector, recommendation sourcing limited to NIST SP 800-53, and dependency on timely updates to the curated GitHub vector stores and quality of user self-evaluations. Planned enhancements are sector-specific vector stores, broader recommendation sources (industry best practices, vendor controls), automated regulatory updates, and expanded UI integrations beyond Slack. Together, these elements position the GRC AI Agent as an efficient, auditable first-pass compliance tool with clear paths for scaling coverage and depth.

Business Purpose and Statement

Our GRC AI Agent assists organizations in conducting risk assessments of their system configurations. It can be used as a way to automate the risk assessment process, and alleviate the burden of determining what data privacy regulations are required to comply with

The landscape of data privacy regulations is constantly changing, and noncompliance results in hefty fines that severely financially impact an organization. Our system is able to quickly determine which regulations apply to an organization, saving employees significant time while helping to avoid paying substantial fines.

Additionally, risk assessments of a system configuration can often be time consuming and complex. By using our system, users are able to begin the risk assessment process by self evaluating their system configuration and receiving up to date recommendations following NIST cybersecurity standards, therefore providing a starting point for system upgrades. This is an efficient way to eliminate some of the grunt work in risk assessments, and provide an overview of possible upgrades to an organization.

Risk assessments are crucial when handling sensitive personal data of your users or consumers. Users of an organization put trust into it by providing personal data, and that sense of trust is necessary for an organization to operate at its best. Our system enables organizations

to conduct efficient risk assessments and receive upgrade options in order to retain user trust and prevent data breaches and cyber attacks

Intended Audience

As the scope of our AI Agent is limited to the business and finance sector, the intended audience for our system is organizations who operate under that sector. Data privacy regulations vary from sector to sector within the US, so currently the AI Agent is equipped to determine what regulations an organization must follow under Federal Data Privacy Regulations that apply strictly to financial or business data.

Although the scope was limited based on the patch work legislation for data privacy within the United States, this AI Agent is able to be utilized by global companies. Our system can determine which International Data Privacy regulations an organization must follow, as well as state specific data privacy regulations for organizations located in the US.

On a user level, the AI Agent can be used by those with a base level understanding of a system configuration. Because “I don’t know” is a valid answer to the self evaluation form, employees of an organization who may not have access to system configuration plans are still able to utilize the service and receive possible upgrades for a system regardless of what they know. The only barrier to using the AI Agent is an understanding of what each subsection in the of the self evaluation form means in terms of system configurations (e.g what Identity and Asset Management is).

Relevant Sources

Data Privacy Regulations

[California Consumer Privacy Act](#)

[Colorado Privacy Act](#)

[Connecticut Data Privacy Act](#)

[Delaware Personal Data Privacy Act](#)

[Indiana Consumer Data Protection Act](#)

[Iowa Consumer Data Protection Act](#)

[Kentucky Consumer Data Privacy Act](#)

[Maryland Online Data Privacy Act](#)

[Minnesota Consumer Data Privacy Act](#)

[Montana’s Consumer Data Privacy Act](#)

[Nebraska Data Privacy Act](#)

[New Jersey Data Protection Act](#)

[Oregon Consumer Privacy Act](#)

[Rhode Island Data Protection Law](#)

[Tennessee Information Protection Act](#)
[Texas Data Privacy and Security Act](#)
[Utah Consumer Privacy Act](#)
[Virginia Consumer Data Protection Act](#)
[Gramm-Leach-Bliley Act](#)
[CFPB Personal Financial Rights Rule](#)
[Financial Data Transparency Act](#)
[Payment Card Industry Security Standard](#)
[General Data Protection Regulation](#)
[Personal Information Protection Law - China](#)
[LGPD - Brazil](#)
[Digital Personal Data Protection Act - India](#)
[Federal Act on Data Protection - Switzerland](#)
[Argentina Personal Data Protection Act - Argentina](#)
[Privacy Act 1988 - Australia](#)
[Personal Information Protection and Electronic Documents Act - Canada](#)
[Law 1518 of 2021 - Colombia](#)
[Danish Data Protection Act - Denmark](#)
[Data Protection Act - Finland](#)
[French Data Protection Act - France](#)
[German Federal Data Protection Act - Germany](#)
[Law 4624/2019 - Greece](#)
[Act of Data Protection and the Processing of Personal Data - Iceland](#)
[Indonesia's Personal Data Protection Law - Indonesia](#)
[Protection of Privacy Law - Israel](#)
[Act on the Protection of Personal Information - Japan](#)
[Personal Data Protection Act - Malaysia](#)
[Federal Law on the Protection of Personal Data Held by Private Parties - Mexico](#)
[Privacy Act 2020 - New Zealand](#)
[Republic Act No 10173 - Philippines](#)
[Federal Law No 152-FZ - Russia](#)
[Protection of Personal Information Act - South Africa](#)
[Organic Law 3/2018 - Spain](#)
[Data Protection Act - Sweden](#)
[Personal Data Protection Act - Thailand](#)
[Law No 18.331 - Uruguay](#)

NIST Recommendations

[NIST Special Publication 800-53](#)

Design Overview

Our AI Agent was implemented in n8n, a workflow automation tool with the ability to connect to third party applications. This workflow takes the user input and executes three AI Agent nodes that evaluate the user input in order to determine what regulations the organization is required to follow and provide possible system configuration upgrades in a readable and concise manner.

We use Slack as the chat interface for our AI Agent. Through n8n, we integrated a bot in a Slack channel that when called triggers the workflow. The workflow sends a form for the user to fill out that asks for a location, sector, state(s) if located in the US, and the number of users the organization collects data on. This form is then used as the input for the AI Agents. This ensures that no information is missing from the user prompt, and the user is aware of what information is necessary for the AI Agent to properly provide correct system configuration upgrades and regulations to comply with.

The AI Agents are provided supplemental information through tools connected to each agent. This supplemental information is called by the AI Agent using vector stores and a Retrieval Augmented Generation. The supplemental information is stored in a GitHub with directories dedicated to NIST recommendations, US State Data Privacy Regulations, US Federal Data Privacy Regulations, and International Data Privacy Regulations. This is the only information the AI Agent can pull from, which prevents outputs from containing incorrect information.

Design Components

Slack Channel

The chat interface of the AI Agent was implemented using Slack and the Slack API. Using a bot created in Slack, the workflow is triggered when a user tags the Automated GRC Agent Bot in the grc-agent-chat channel. From there, the workflow will continue by mentioning the user that tagged the bot in a message instructing the user to check their DMs for further instructions. From here the user is given a Slack form, which is explained in detail below. Once the Slack form is submitted the AI Agent is able to use this information for the analysis.

Once the workflow is completed, the final output is sent back to the user via the DMs functionality in Slack. Because n8n provides Slack integration, we were able to use the Automated GRC Agent Bot to connect the Slack channel to the workflow itself. Additionally all functionality that can be executed within Slack is able to be automated via n8n nodes, giving the AI Agent the ability to communicate with the user and receive input through a form.

Self Evaluation Form

The Slack form is a node feature in n8n, that we utilized to obtain user input from the Slack Channel. This form prompts the user to provide the location, sector, states(s) if the organization is located in the US, and the number of users the organization collects data on. The second part of the form is a self evaluation the user completes regarding their organization's system configuration. The system configuration is broken into subsections that the user will rate the organization's implementation of on a scale from 1 to 10. Then the user must explain why they gave the organization the rating for each subsection. This provides the AI Agent with the information necessary to conduct an analysis on the organization's system.

AI Agent Node

Our workflow uses three AI Agent nodes to complete the analysis of the system configuration. Each agent receives an input and, using a unique system prompt, executes its purpose using built in tools and the Open AI API model.

The first AI Agent the workflow hits is the Regulations Agent. This Agent is designed to determine which regulations an organization must comply with based on the location, sector, state(s), and number of users the organization collects data on answers from the self evaluation form. Its system prompt explicitly tells it to call the Vector Stores tools, which will be described in detail below. These tools provide the AI Agent with information regarding data privacy regulations. The system prompt also informs the AI Agent that it may only pull information from those vector stores to prevent any inference or hallucination.

The second AI Agent the workflow hits is the Recommendations Agent. This Agent is designed to evaluate the user's self evaluation form and provide recommendations for system upgrades based on the ratings and explanations from each subsection. Its system prompt explicitly tells it to call the Vector Stores tools in order to obtain the NIST recommendations directory to inform what recommendations it should provide to the users. The AI Agent ranks the different subsections based on the rating the user gives it. If the rating is 3 or less, that subsection is treated as high priority. If the rating is between 3 and 7, that subsection is treated as medium priority. If the rating is 7 or above, that subsection is treated as low priority. This allows the AI Agent to focus more heavily on the subsections the user believes have worse implementations.

The last AI Agent the workflow hits is the Summary Agent. The input for this AI Agent is the merged data from the Regulations Agent and Recommendations Agent. This Agent is designed to take the outputs from the first two agents and produces a summary that is readable and concise to send to the user. This ensures the final output is not too dense, or contains information the user does not need.

All three AI Agents use the OpenAI API model for their LLM base. N8n has the ability to integrate several AI APIs, and we selected OpenAI for cost effectiveness. The same model is used on all three agents to reduce overall cost of processing an input. The model is connected

using an OpenAI account. Connecting the account through n8n allows us to access the API for the gpt-mini-5 model.

Vector Stores

In order to provide the AI Agents with supplemental information to help inform the outputs given to the user, we've implemented a Retrieval Augmented Generation to pull files from our GitHub. Our GitHub is broken into directories that correspond to the different vector stores the AI Agents can pull information from as needed. For example, if the AI Agent needs to look for an International Data Privacy Regulations, it calls the tool that corresponds to the International Regulation Vector Store. This then triggers the RAG, and using HTTP requests, the correct information is retrieved from our GitHub. Each file in our GitHub is formatted as a JSON. This formatting choice allows the file to be easily parsable by the AI Agent as well as easily appendable to account for the rapidly changing data privacy regulations.

The vector store tools are only called when necessary for the analysis the AI Agent is completing. This allows the AI Agent to be more efficient because instead of combing through all of our collected data on both regulations and recommendations, it only looks through the specific regulations or recommendations that pertain to the user input.

Software Flow

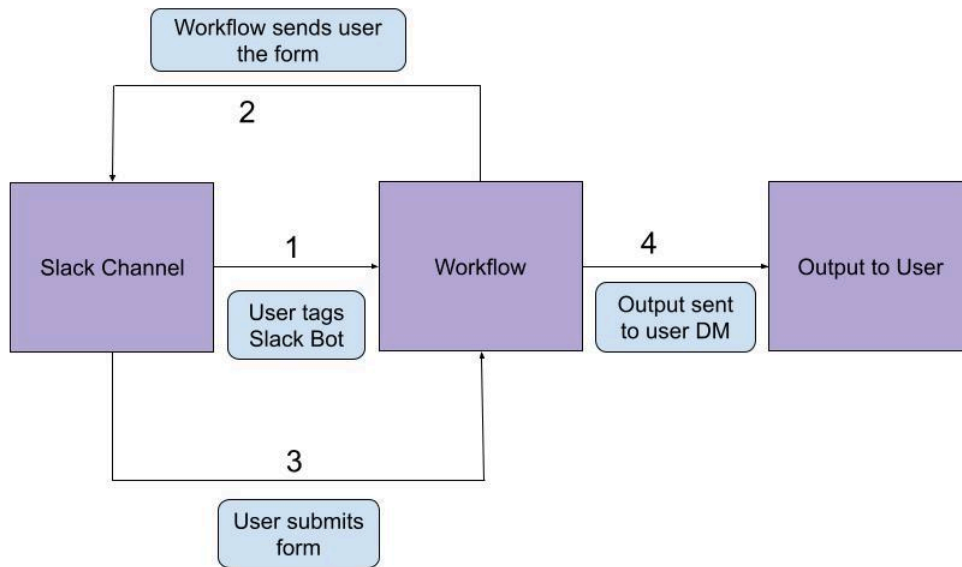


Figure 1: The Software Flow of the GRC AI Agent

The workflow is triggered when the user tags the Automated GRC Bot in the grc-agent-chat Slack channel. The workflow is designed to listen for any mentions to that bot in the grc-agent-chat. Once the user tags the bot and sends a message in the channel, the workflow begins executing. The workflow will then send a message to the grc-agent-chat channel, tagging the user that called the bot in a message. Once this message is sent, the user will also receive a DM from the Automated GRC Bot with the form the user must complete in order to get an analysis. After the user submits the form, the workflow continues by formatting the information into a JSON, and sending the JSON through the AI Agents. Once all three AI Agents have executed, the output is sent back to the user through Slack DMs from Automated GRC Bot.

Additional Design Considerations

In order to make the AI Agent run smoothly, we incorporated several nodes that improved functionality of the workflow. This includes nodes that edit the input fields received from the Slack form the user input form. This node simplifies the way the input is presented to the actual AI Agent nodes. In addition to editing fields, we also incorporated nodes that merged datasets together for the final summary node. This enables us to provide only one input for the entire analysis, instead of two separate inputs for regulations and recommendations.

When first developing what the scope of the AI Agent would be, we considered handling all sectors and industries. However, due to the difference in data privacy regulations in the US regarding different types of personal data, we limited the scope to one sector for this implementation for the sake of the time frame allotted to complete the project. Handling different sectors and their regulations could be added in the future using the GitHub and additional vector stores. Additionally, because of time constraints we limited what information we used to inform the recommendations output. As of right now, only NIST recommendations are being used, but in the future, additional data regarding possible system upgrades and best practices could be added in order to provide more tailored upgrades based on industry and sector.